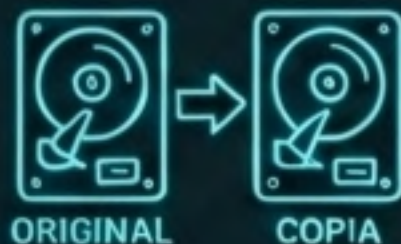


Lección 06: Del Hash a la Decisión



Alcance y Autorización

La intervención técnica está estrictamente delimitada por el mandato legal o corporativo.



Original vs. Copia de Trabajo

Preservar la fuente original siempre que sea posible y realizar el análisis sobre una copia de trabajo. Si es necesario interactuar con una fuente activa, la acción debe ser autorizada, mínima y documentada.



Función Hash

Algoritmo matemático (ej. SHA-256) que genera una huella digital de longitud fija a partir de los datos. Permite comparar dos estados y detectar cambios.



Documentación

Todo paso, desde la recepción hasta el análisis, requiere un registro detallado y regurado y reproducible.



QUÉ NO DEMUESTRA UN HASH: Un hash coincidente (OK) demuestra **igualdad matemática** con una referencia. **NO** demuestra **autenticidad, autoría, intención ni inocencia.**

Fases Metodológicas: Evaluar, Preservar y Analizar

Pregunta Guía: ¿Qué preservar primero y bajo qué condiciones aceptarlo para su análisis posterior?

Evaluar (ISO/IEC 27037)

Definición: Diagnosticar el origen, integridad, riesgo y valor de una fuente.

Utilidad: Determinar si lo recibido sirve y qué requiere acción inmediata.

Ejemplo: Revisar si un PCAP cubre la fecha del incidente.

Preservar (ISO/IEC 27037)

Definición: Proteger la fuente para evitar su alteración o pérdida.

Utilidad: Garantizar que la evidencia mantenga su valor legal y técnico.

Ejemplo: Solicitar la preservación o retención del buzón o cuenta de correo al custodio o proveedor.

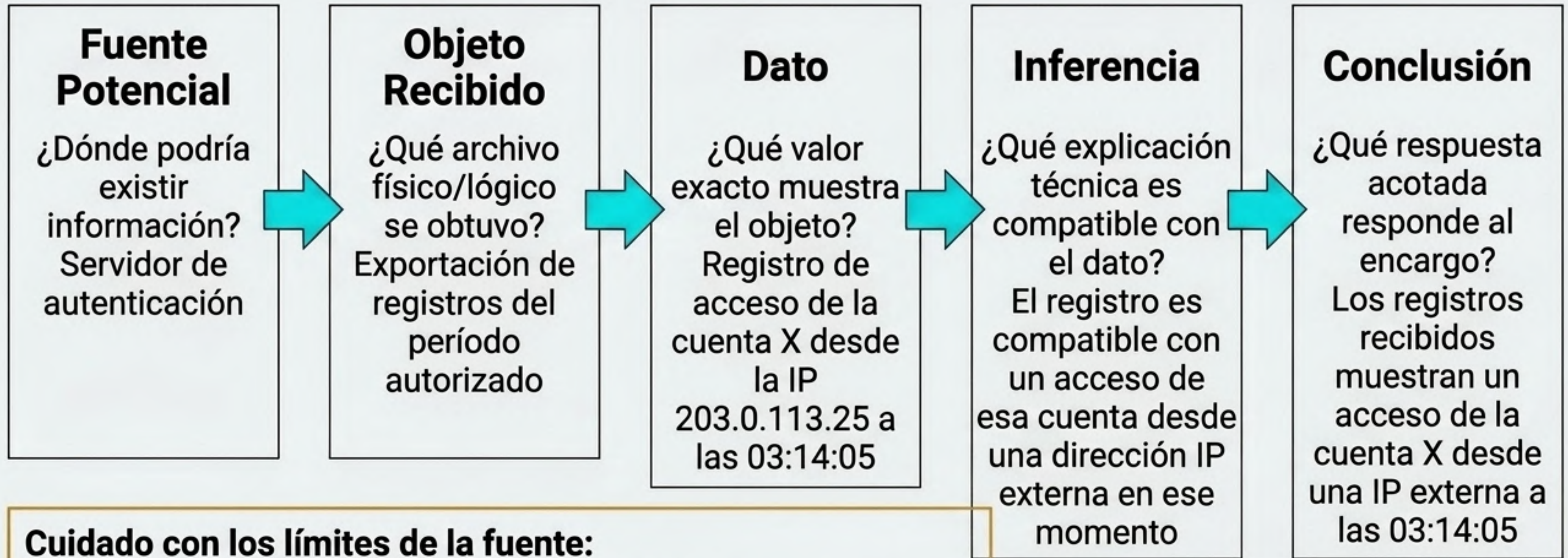
Analizar (ISO/IEC 27042)

Definición: Extraer datos, correlacionar eventos y formular inferencias.

Utilidad: Responder técnicamente a la pregunta pregunta de la investigación.

Ejemplo: Extraer direcciones IP de las cabeceras para trazar una ruta. (Fuera del alcance de esta lección).

De la Fuente a la Conclusión



Cuidado con los límites de la fuente:

Índice de PCAP (pcap-indice.csv) ≠ Tráfico de red real (PCAP).
Inventario de Respaldo (respaldo-bd-inventario.csv) ≠ Respaldo de la Base de Datos.

Esto no identifica por sí solo a la persona que utilizó la cuenta.

Características de la Evidencia Digital



Intangible

Requiere hardware/software para leerse.

[Precaución: Registrar siempre la herramienta y versión utilizadas.]



Frágil y Alterable

Modificable sin dejar rastro visible.

[Precaución: Minimizar interacción; fijar referencia de integridad inmediatamente.]



Volátil

Puede desaparecer por diseño o falta de energía.

[Precaución: Decidir y ejecutar la preservación de forma temprana.]



Replicable (Sin contexto)

Los bytes se copian exactos, pero pierden entorno.

[Precaución: Preservar y documentar siempre el contexto original (quién, cuándo, cómo).]



Dependiente del Entorno

Requiere un formato, proveedor o clave para interpretarse.

[Precaución: Preservar el formato nativo y las condiciones de lectura.]



Dispersa y Sensible

Repartida en múltiples sistemas con datos privados.

[Precaución: Evaluar fuentes individuales y aplicar minimización de acceso.]

Evaluación de Origen e Integridad

Origen y Autenticidad

Procedencia: ¿Quién produjo el objeto, desde qué sistema y cuándo?

Formato Nativo: ¿Se transformó la evidencia (ej. captura de pantalla, reenviado) o se entregó en formato original?

Contexto de Exportación: ¿Se aplicaron filtros de búsqueda, limitación de períodos o zonas horarias específicas?

Integridad

Técnica: El valor hash actual coincide matemáticamente con una referencia conocida.

Procedimental: Existe una cadena ininterrumpida que registra quién tuvo el objeto, cuándo, y qué hizo con él.



EL LÍMITE DEL HASH DE RECEPCIÓN: Un hash calculado al recibir un archivo solo cubre su integridad desde el momento de la recepción. No prueba que el archivo no haya sido alterado en su vida previa antes de ser entregado.

Utilidad, Suficiencia y Valor Potencial

Relevancia

Ayuda a responder una pregunta autorizada. (Ej. Tener muchos gigabytes de logs no significa que sean relevantes al caso).

Suficiencia

Existe respaldo suficiente, individualmente o en conjunto con otras evidencias, para sostener una afirmación concreta.

Validez

El método utilizado es adecuado para su propósito y permite obtener resultados revisables, repetibles o reproducibles según corresponda (ISO/IEC 27042).

Trazabilidad

Permite auditar el camino exacto desde la conclusión hasta el objeto y el registro original.

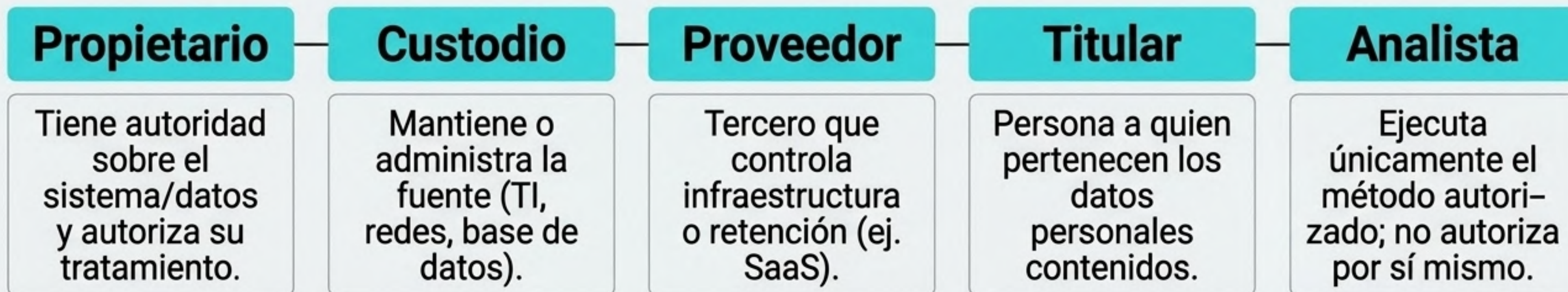
Valor Potencial

Lo que la fuente podría aportar si se preserva y analiza correctamente.

El Límite de la Suficiencia: Un archivo EML recibido sin la cabecera Received limita reconstruir la ruta completa del mensaje, pero esa ausencia no invalida por sí sola el resto de los datos

El Límite del Valor Potencial: Potencial: Un respaldo previo al incidente sirve como estado base comparativo; no registra hechos ocurridos después. Una fuente sin analizar no prueba nada.

Propiedad, Custodia y Autorización

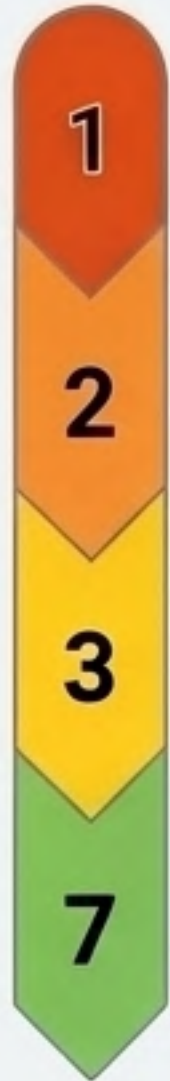


Leyes y Límites

- **Regla de Oro:** Autorizar $\neq$ Ejecutar.
- Dispositivos personales y servicios de terceros requieren trato especial y minimización.
- **Legislación:** El tratamiento de datos se rige por la Ley 19.628 vigente (la Ley 21.719 entra en vigencia el 01-12-2026).
- **Protocolo:** Ante duda de propiedad, presencia de datos sensibles, o falta de autorización explícita: DETENER Y ESCALAR.

Volatilidad y Amenazas (RFC 3227)

Guía operativa basada en el orden de volatilidad de RFC 3227



1. Registros y caché del procesador.
2. Tabla de rutas, caché ARP, tabla de procesos, estadísticas del kernel y memoria RAM.
3. Sistemas de archivos temporales.
4. Disco.
5. Registros remotos y datos de monitoreo.
6. Configuración física y topología de red.
7. Medios de archivo o respaldo.

Tipos de Amenazas

Técnicas: Reinicio del sistema, rotación de logs por falta de espacio, retención de SaaS vencida.

Accidentales: Usuario abriendo un archivo original, reenvío de correo que altera cabeceras.

Procedimentales: Transferencia sin control de integridad, acceso excesivo sin registro.

Intencionales: Modificación o borrado deliberado por actores interesados.



Riesgo técnico de pérdida NO equivale a intención de ocultamiento.
Un reinicio es una amenaza técnica, no necesariamente un sabotaje.

Cómo Priorizar la Preservación

Para justificar la prioridad, evalúa en conjunto:

- **Ventana de pérdida**
- **Unicidad**
- **Valor potencial**
- **Dependencias**
- **Restricciones**

Ventana de pérdida: ¿Cuándo se sobrescribe, apaga o elimina?

Unicidad: ¿Existe otra copia equivalente y verificable?

Valor potencial: ¿Qué pregunta clave responde?

Dependencias/Restricciones: ¿Tenemos autorización legal, personal competente, y no interrumpiremos un servicio crítico?

Mostrar prioridades

Mostrar prioridades paralelas es clave.

Ejemplo: Redes extrae los logs volátiles del Firewall, mientras TI asegura la RAM de un servidor.

Atención: Lo más volátil no siempre es lo más valioso. Si no hay autorización o competencia técnica, la acción correcta es mantener el estado y escalar.

Construcción del Plan de Preservación

Formas de Preservar

- 1 Mantener estado:** (Ej. No apagar el equipo).
- 2 Impedir pérdida:** (Ej. Solicitar retención legal / legal hold a un proveedor SaaS).
- 3 Obtener copia verificada:** (Ej. Imagen forense o extracción lógica).

ID / Alcance: Identificador único y qué queda fuera de la preservación.

Autorización: Quién autoriza y quién es el responsable de ejecutar.

Método y Formato: Cómo se preserva el formato nativo sin alterar el contexto.

Integridad: Referencia (Hash) y momento de cálculo.

Almacenamiento y Acceso: Medio cifrado, control estricto, política de retención.

Condición de Detención: Límite claro (Ej. Detener si la exportación incluye cuentas fuera del alcance).



El analista nunca inventa la política de retención; la hereda de la autorización legal o corporativa.

Resultado Técnico y Estado de la Evidencia

Aceptada: Identificada, dentro del alcance, con procedencia suficiente e integridad coherente con la referencia disponible.

Aceptada con Condición: Conserva valor, pero requiere información adicional (ej. faltan parámetros de exportación).

Aislada por Discrepancia: existe un fallo de integridad o una discrepancia técnica no explicada, por ejemplo un hash FAILED.

Pendiente de Adquisición: Evaluada y priorizada, pero aún no preservada.

¿Qué hacer si un control de hash indica FAILED?

Conservar: No borrar el objeto recibido, el manifiesto original ni la salida del error.

Registrar: Documentar la discrepancia exacta.

Aislar: Separar la evidencia de los datos de trabajo.

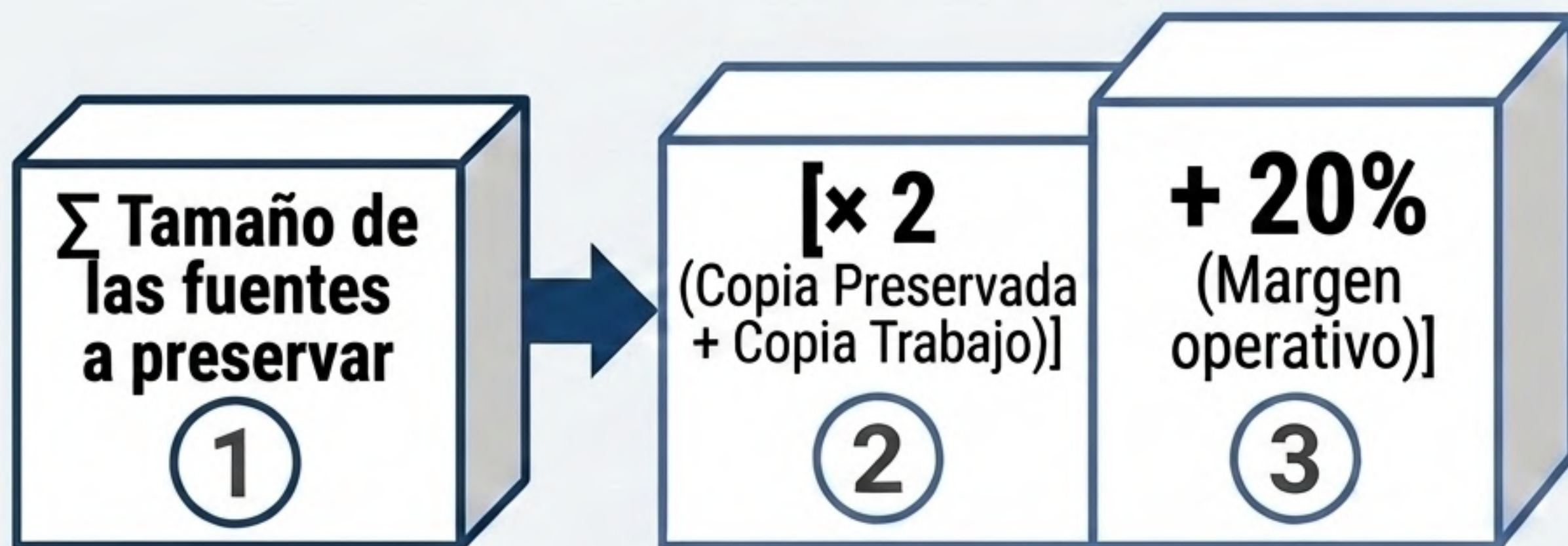
Escalar: Informar al responsable para decisión.

Si no existe una referencia hash, no hay una discrepancia demostrada: la fuente puede quedar aceptada con condición hasta obtener un control adecuado.



NUNCA regenerar un manifiesto para ocultar un error, ni inventar causas técnicas para un FAILED.

Estimación de Almacenamiento



Condiciones de Resguardo:

- Cifrado cuando la sensibilidad de los datos o la política aplicable lo requieran.
- Claves gestionadas en un canal separado.
- Control de acceso nominal (sólo equipo autorizado).

Ejemplo Paso a Paso:

Fuentes: Servidor (12 GiB) + RAM (3 GiB) = 15 GiB.

Multiplicador: 15 GiB $\times$ 2 (Una preservada, una para análisis) = 30 GiB.

Margen operativo para registros, hashes, índices y otros archivos auxiliares: 30 GiB + 20% = 36 GiB.

Decisión: Elegir un medio de almacenamiento con capacidad real superior a 36 GiB.



No confundir: calcular usando el tamaño real de la fuente, **NUNCA** usar el tamaño del archivo .csv (índice o manifiesto) que la describe.

Comandos Mínimos de Trabajo Forense

Comando	Qué hace	Qué NO demuestra
<code>mkdir -p / cp -a / cd / pwd</code>	Crea la carpeta de trabajo, realiza una copia conservando la estructura y los metadatos disponibles, cambia a esa ubicación y permite comprobar la ruta actual.	No valida ni autentica el contenido de los archivos copiados.
<code>sha256sum -c manifest_entrega.sha256</code>	Compara las huellas calculadas de los archivos contra las registradas en el manifiesto.	sha256sum compara, no repara. Un FAILED no demuestra quién alteró el archivo.
<code>sed -n '1,/^\\$/p' archivo.eml</code>	Muestra únicamente las cabeceras del correo hasta la primera línea vacía, sin mostrar el cuerpo del mensaje.	La ausencia de una cabecera en el objeto recibido no demuestra que nunca existió en el servidor origen.

(Nota: Uso exclusivo sobre la copia local de trabajo. No modificar los archivos recibidos ni el manifiesto. No usar redirección > ni sudo)

Síntesis Aplicada: Ejemplo Resuelto

Escenario: 3 Fuentes

Fuente 1: RAM del Servidor (Activo)

Evaluación: Volatilidad Extrema, Alta Sensibilidad. Depende de energía.

Decisión: Nivel 1A. Preservación inmediata por personal competente (mantener encendido).

Fuente 2: Logs de Retención Corta (SaaS)

Evaluación: Volatilidad Alta (rotación en 24h), Custodio externo.

Decisión: Nivel 1B. (Paralelo a F1). Solicitar legal hold / exportación al proveedor.

Fuente 3: Respaldo Estable (Offline)

Evaluación: Volatilidad Baja, Valor Potencial Alto (estado previo). Riesgo técnico bajo.

Decisión: Nivel 2. Preservar posteriormente; asegurar cadena de custodia del medio físico.

Razonamiento

La priorización no es lineal; F1 y F2 avanzan en paralelo porque involucran distintos responsables y tipos de amenazas. F3 espera por ser estable.

Razonamiento

Mapa de Flujo Final y Registro Reproducible



Plantilla de Registro

1. Alcance: (Mandato y exclusiones).	2. Fuente/Objeto: (Identificador y descripción).	3. Método: (Herramienta/comando ejecutado).	4. Resultado: (OK, FAILED, o salida técnica).
5. Decisión: (Prioridad y estado asignado).	6. Fundamento: (Razonamiento de la prioridad).	7. Limitación: (Condiciones o metadatos ausentes).	8. Conclusión: (Respuesta técnica).

PRESERVAR GESTIONA DATOS, NO JUZGA ACCIONES.

El plan decide cómo proteger fuentes potenciales; no demuestra autoría, culpabilidad, ni intenciones maliciosas de ninguna persona.